

The Expel 2026 Annual Threat Report

An in-depth look at how last year's attacks should inform your defense strategy today



Table of Contents

- Letters from leadership
- Executive summary
- Cybersecurity events in 2025
- Identity attacks: Credentials are valuable, protect them...
- Endpoint attacks: Malware is king
- Cloud infrastructure attacks: Lower activity, higher risk
- Industry insights
- Defending attack surfaces
- Signal vs. noise: making the most of alerts**
- Predictions for 2026

Letters from leadership

Welcome to our Expel 2026 Annual Threat Report

Letter from the CSO:

If there's one thing 2025 made clear, it's that speed matters more than ever—and I don't just mean how fast threat actors move.

The gap between detecting a threat and actually doing something about it is where breaches happen. We saw it play out across our customer base all year: Many intrusions succeeded simply because the “basics”—like multifactor authentication (MFA) or proper configurations—weren't fully optimized.



This year's report digs into the data behind nearly a million alerts. You'll see how identity remains the primary attack surface, and which endpoint and cloud threats continue to evolve. But beyond the numbers, you'll find practical insights from our analysts who handled these threats in real time. What worked. What didn't. What you can do about it.

We're sharing this because cybersecurity is a team effort. The more we learn from each other's experiences, the harder we make it for adversaries. We hope this report helps you head into 2026 with clearer direction and a few less unknowns.



Greg Notch
CSO, Expel

Letter from the Director of Threat Operations:

Effective security is the disciplined pursuit of prioritization. It's not an abstract exercise in pursuing the art of the possible in understanding attacks—that doesn't deliver impactful results. It's the concrete and systematic work of risk mitigation and remediation. To deliver measurable results, we must progress from speculative threat modeling to a defensive strategy in tune with active threats in the wild.

This past year reaffirms an ever-present concern in cybersecurity: The vast majority of attacks that work today are not novel or sophisticated. They are successful because they exploit known and preventable gaps. The humbling truth is the attackers' wins align to gaps in deployed security controls and configuration weakness, not technical gaps in security solutions.

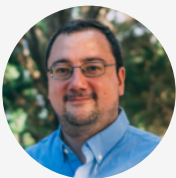
So where should we focus in 2026?

There are some changes that can't be ignored. AI doesn't feature prominently in our attack data—but this is not to say it has no place in defense considerations. There are, of course, data loss prevention (DLP) and governance, risk, and compliance (GRC) considerations, but two other noteworthy areas demand attention.

AI systems themselves present a very prominent supply chain concern. Your data, automations, and implementations may be in the hands of a supplier that would be advantageous for an attacker to control. AI is also impacting attacker tooling and capabilities. Evidence is emerging that attackers are leveraging AI for tasks like obfuscating fingerprinting techniques, fuzzing code to identify exploitable bugs, and AI-assisted coding.

However, despite AI being new, the defensive strategy is still clear: keep focus on the fundamentals, and then audit the fundamentals again. Our data shows where the attacks are happening—align your budgets, your strategy, and your tactics using the data herein. Operationalize a lifecycle management strategy that includes an audit to make sure you're delivering on your tactical plan. Find and fill your gaps as they overlap with our data.

For those keeping watch, stay vigilant!



James Shank
Director of Threat Operations, Expel



Executive summary

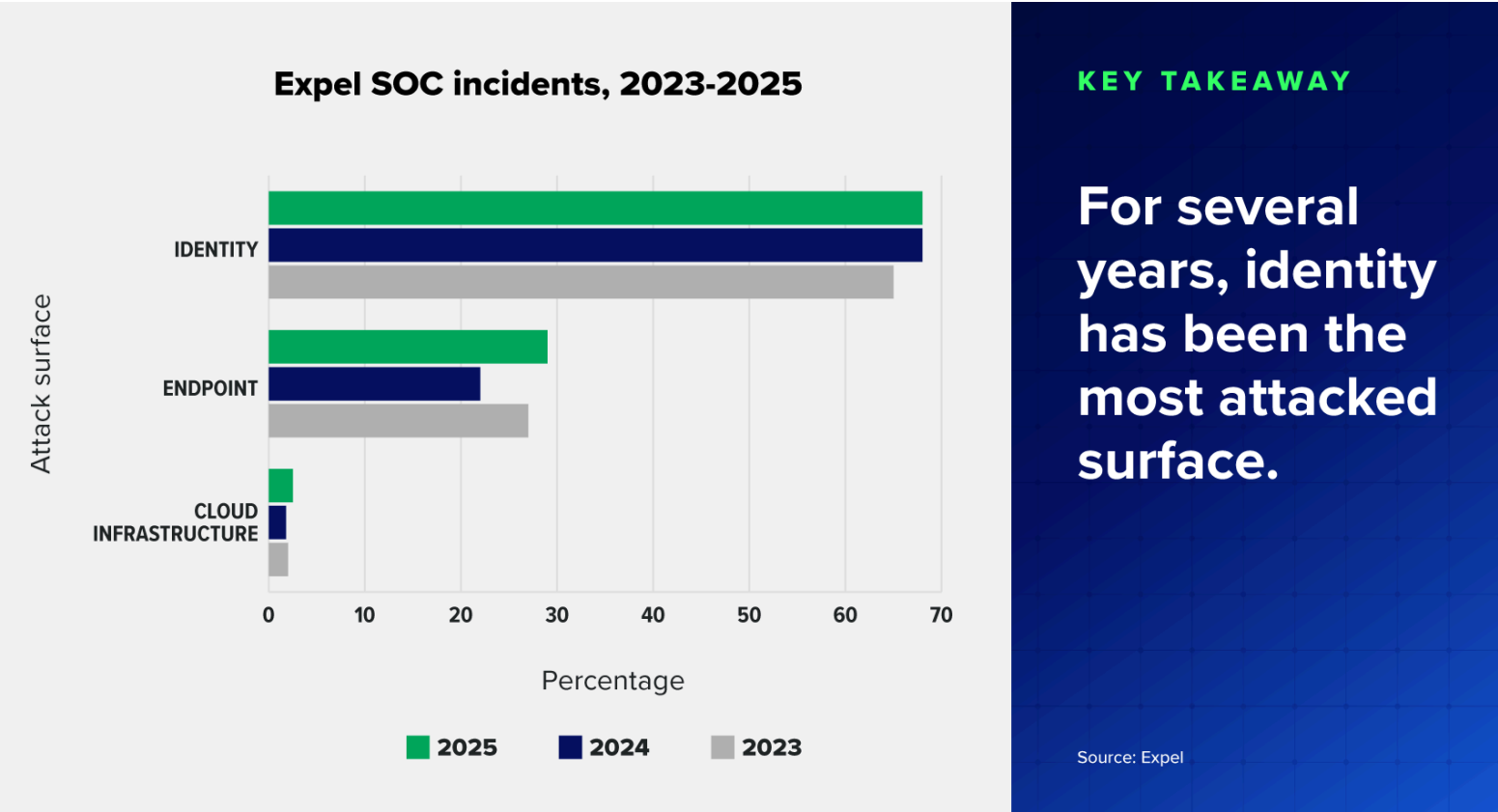
At Expel, we see and field cybersecurity challenges every day, helping our customers identify, remediate, and prevent attacks. We're on the front lines, and we see the latest attacks as they emerge.

Last year across our customer base, our security operations center (SOC) triaged nearly a million alerts generated across every major attack surface. And, of those alerts, our SOC investigated tens of thousands of incidents. As the SOC handled these alerts and incidents, they took notes; notes which were ultimately compiled into this report.

The next 10,000 words (give or take) paint a picture. They give a macro-level view of attacker trends and reveal behaviors you may have never considered.

We also finish the report by showing real data on how Expel-written detections (versus generic vendor detections) allowed our SOC to shut down the vast majority of observed incidents early in the MITRE ATT&CK framework kill chain. **Detection is great. But early detection and quick action on those detections are equally key to business resilience.**

Here in our *2026 Annual Threat Report*, we see the threat landscape through three primary attack surfaces: identity, endpoint, and cloud infrastructure. Most incidents we see fall into one of these three categories. To set the table and give you the broadest perspective possible, here's how our incidents divided between those three buckets versus prior years:



The primary threat by volume comes from identity-based attacks, where actors successfully steal user credentials and authentication tokens for accessing accounts. **This year, 68.6% of incidents involved identity.** Each of these incidents represent gaps in security which can have a massive impact on an organization.

However, some good news: more than half of the identity-based attacks (52.3%) where attackers used legitimate credentials failed immediately thanks to security controls and MFA. Even so, attackers still managed to gain access in far too many of these incidents (47.7%).

To the surprise of no one, identity threats take the throne (again) and continue to wreak havoc on organizations. But has identity security been solved? Hold that thought; we'll cover that in one of our many security practitioners' "field notes" write-ups that we've included this year.

Following identity, the next most common incident type originated from endpoints (enterprise computers and servers), making up 29% of incidents. This category largely consists of opportunistic malware (63.9%), hands-on hacking attempts (21.4%), and server-side vulnerability exploitation (2.3%).

Endpoint attacks in 2025 were more "jazz standards" than groundbreaking; bad actors improvised on what already works. If it's not broken, don't fix it, right? Hot tactics in this category include [suspicious PDF editors](#) (which bundled legitimate functionality with malware installation) and the ever-effective ClickFix social engineering technique (which [we've researched extensively](#)), where users were tricked into copying, pasting, and executing malicious scripts.

Last but not least, **cloud infrastructure comprised a small but growing portion (2.5%) of the types of incidents that we detected. And it's an important one to defend, considering this is where proprietary data often lives and vital applications run.** A cloud compromise could mean

widespread organizational disruption. Many of these incidents involved unauthorized access to cloud resources through misconfigurations, vulnerabilities, and exposed cloud secrets.

A peek behind the (data) curtain

Across our customer base, organizations experienced an average of 13 incidents during 2025, with a median of three incidents. Why the gap between median and mean? The reason becomes clear when we look at company size:

Size	Incidents
Small (0-1,000)	6.3
Medium (1,001 – 10,000)	23.8
Enterprise (10,001+)	67.8

When we break this down by organization size, the pattern becomes clear. Small organizations with fewer than 1,000 employees saw an average of six incidents per year—manageable, but still requiring vigilant monitoring. Medium-size organizations experienced 24 incidents on average, reflecting the larger attack surface and visibility to attackers. Meanwhile, enterprise customers with over 10,000 employees faced the largest burden of an average of 68 incidents per year.

This change based on organization size demonstrates exactly why managed detection and response (MDR) is useful across all organization sizes. The challenge faced by small organizations isn't volume, it's staffing. Teams often lack the ability to staff up for round-the-clock monitoring, yet even a handful of incidents can be devastating without a proper response. In contrast, the challenge for enterprises is sustaining high-quality responses at volume, all the while avoiding burnout.

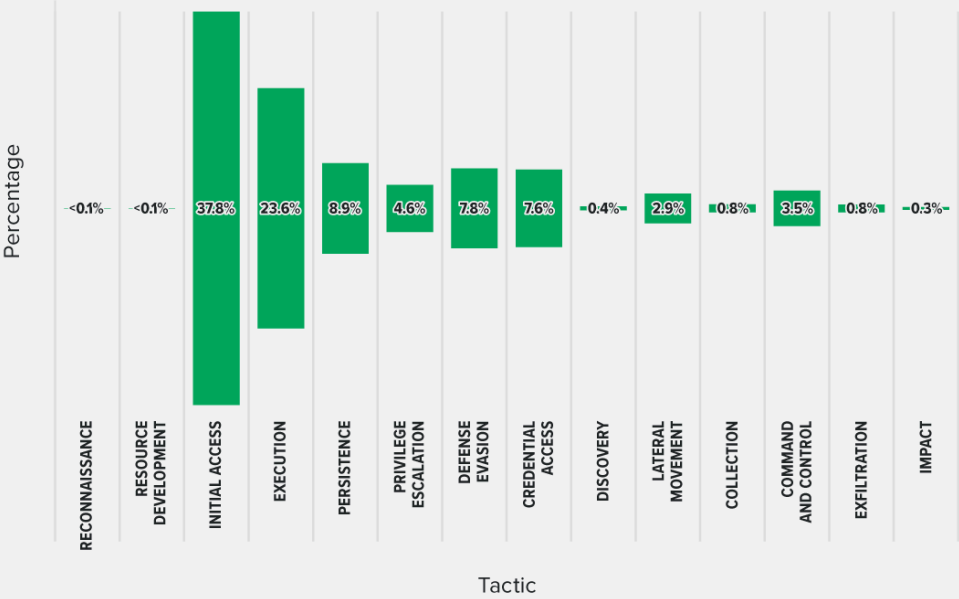
This is where MDR delivers a key advantage. It can transform security from a cost center into a predictable operational expense with adequate coverage.

Looking at the data, it's clear our detections engineers have been doing their part to stop attackers. Three quarters (75.6%) of the detections we monitored to protect our customers were either Expel-written detections or Expel-enhanced vendor detections. Most significantly, for high and critical severity incidents—where response speed is critical to avoid severe impacts—Expel's custom detections were responsible for 78.8% of the detections.

As mentioned above, early detection and quick action are equally important. When dealing with high and critical incidents, with our auto remediation features enabled, **our SOC's current mean time to respond (MTTR) is an astonishing 13 minutes**. This speed, combined with our early-stage detection capabilities, creates a defensive advantage that significantly reduces the window of opportunity for bad actors.

To round out the report, we prove that defensive advantage by plotting last year's incidents across MITRE ATT&CK tactics. We found that these incidents were primarily identified by detections that alert early in the kill chain, focusing most on the initial access and early execution phases.

Incident alerts by MITRE ATT&CK tactic



KEY TAKEAWAY

Shifting left:
Value is delivered by interrupting attacks *early*, reducing impact.

Source: Expel

This early-stage detection provides security teams with critical opportunities to contain threats before attackers can get to more damaging activities, like exfiltrating data or deploying ransomware. Expel's ability to capture incidents at this early stage fundamentally improves security outcomes by minimizing the impact of successful intrusions.

Want more insights into what we saw in 2025, or further details about some of the attacks and trends we've touched on here? Interested in hearing first-hand accounts and analysis of what our SOC analysts dealt with in the last year?

LET'S DIG IN.



TIMELINE Cybersecurity events in 2025

There's never a dull moment in cybersecurity. This timeline chronologically lays out the hottest cyber news and intel, alongside trends that we experienced within our SOC.

January 8

Ivanti Connect Secure identified and patched a remote code execution (RCE) zero-day vulnerability.

February 2

One of two days in 2025 with the fewest number of incidents our SOC investigated.

March

Ransomware gang Black Basta's chats were leaked, giving defenders insight into their code-signing certificate tactics.

March 10

One of two days in 2025 with the fewest number of incidents our SOC investigated.

March 14

Security researchers found that a GitHub action (tj-actions) used by 23,000 repositories was trojanized, impacting the down-stream repositories.

[Read blog →](#)[Read blog →](#)[Read article →](#)

ATTACK SURFACE TRENDS

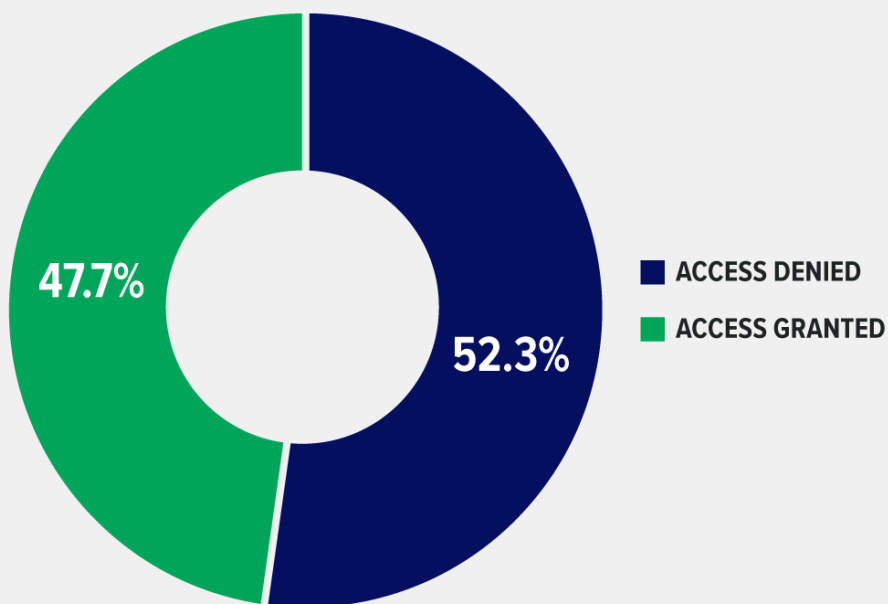
Identity attacks: Credentials are valuable, protect them accordingly

Identity is a frequently targeted attack surface that—as our data shows—drives a substantial portion of security incidents. When a user's account is compromised, an attacker can leverage that to access email, business applications, or collaboration applications.

Over the past several quarterly threat reports, we've split identity-based attacks into two categories:

- **Access denied:** Legitimate credentials have been stolen and were used, but the attacker was unable to gain access.
 - These are important to treat as incidents for multiple reasons. The attacker may have only been blocked temporarily. For example, if conditional access blocked the attacker due to geo-location or user-agent, these features of their login can be changed easily and attempted again.
- **Access granted:** Legitimate credentials have been stolen and were used, and the attacker was able to gain access.
 - These incidents require quick response to prevent sensitive files from being accessed or to identify actions the actor was able to take, such as adding their own multifactor authentication device.

Valid credential use in 2025



KEY TAKEAWAY

More than half of all valid password attacks were stopped by MFA or other conditional authentication controls.

Source: Expel

Access denied

Most identity incidents we saw this year (52.3%) were instances where valid credentials were stolen but attackers failed to gain account access. In these cases, the attackers were blocked by existing security controls such as conditional access policies, which restrict user login

locations or require company-managed devices to log in.

These “failed attempts” are treated as incidents since not all of the risk has been mitigated. When these failed logins occur, it can indicate the user has fallen victim to an attack such as a credential harvester or infostealing malware. The blocked login may have only been blocked temporarily, and a persistent actor may overcome the security policy by changing their user-agent or geo-location using a VPN. It’s essential for security teams to take these cases seriously, investigate the impacted account, and assess the potential impact.

The following behaviors were most frequently identified and blocked during incidents:

- Attempts to connect from known phishing infrastructure
- Connections from suspicious locations (e.g. not where the user resides)
- Logins through TOR nodes or unauthorized VPN applications
- Connections from unrecognized devices (e.g. not a work laptop)

Success of these attempts is determined in part by an organization’s security posture. For some organizations, logins from suspicious sources are blocked automatically. For others, the activity may only generate an alert. The latter scenario creates a delay that can increase the risk of experiencing a higher impact incident. **Cybercriminals are often quick to leverage access to a network once it’s achieved, so narrowing the gap between signal and action is critical to thwarting these identity-based attacks.**

FIELD NOTES

Identity alerts in action—identifying and stopping them

05:07

JOSH CARTER
MANAGER, SOC OPERATIONS

Identity alerts are strong indicators of attackers attempting to gain access to an environment. We know that detecting and stopping these login attempts are critical to preventing further reconnaissance, persistence, lateral movement, and post-exploitation activities from happening. This past year, 68.6% of all incidents reported by the Expel SOC were identity-based. Let’s dive deeper into what these incidents were and how we, as a security community, can get ahead of the adversary and use our existing tools to stop these attacks from happening.

One of the easiest ways to identify suspicious logins is by either adding approved (or “expected”) geographic locations to allow lists or blocklisting unapproved (or “unexpected”) geographic locations. If you’re an organization that works within a specific geography, this is a pretty easy task to undertake using your existing security tools.

Incidents involving a suspicious location accounted for 12% of identity incidents in 2025. However, it's worth noting that if you're a larger enterprise, hire contractors from outside your geographical region, and/or have employees that travel to other locations, you can open yourself up to lots of false positive alerts. If you're writing your own login detections, make sure to consider factors such as acceptable VPN usage, active sessions, and user agents.

Speaking of user agents, Axios user agents continue to be a strong indicator of attacker activity. This past year, 9.5% of incidents were identified simply by a login attempt from an Axios user agent. So if you know that Axios isn't something your organization uses, consider adding conditional access blocks for that user agent.

Of course, known malicious indicators are always a great way to quickly identify attacker activity. Expel's Threat Intel and Threat Hunting teams work in tandem with the SOC to create new detections based on real-world, in-the-moment attacker behaviors. Last year, Expel identified 2% of incidents with detection rules written by the Threat Intel and Threat Hunting teams. As a security team, we shouldn't wait until we're under attack from the latest and greatest cyber threats. We need to learn from others and share what's happening to understand the tactics and techniques being used in new campaigns now.

Finally, phishing emails continue to be the primary tool used by attackers to trick users into handing over their credentials. 12% of incidents last year were attributed to successful phishing attacks. Employee training continues to be the number one way to fight social engineering techniques. However, adopting additional tools to mitigate phishing attacks will help when a human inevitably makes a mistake.

Access granted

What happens when entry isn't denied? **This was the case for 47.7% of identity incidents in 2025—access was granted to platforms by using valid (albeit stolen) credentials.** In our role, it's in our (and our customers') greatest interest to shut attackers out. When identified, our team investigated and responded to the activity. We immediately shut down the compromised accounts, stopping the attackers in their tracks before they could cause further damage.

However, there is more nuance in the severity of these attacks. While bad actors do gain access to sensitive data at times, in the vast majority of incidents, no further activity is observed after they log in.

In order to distinguish between these two types of incidents, we began sorting these attacks into two further classifications in the second half of 2025:

- **Access granted:** A legitimate user session was accessed using valid credentials and MFA responses. There was no immediate evidence of secondary malicious activity (such as data exfiltration or lateral movement).
 - This can be a result of adversary-in-the-middle (AiTM) platforms. Phishing-as-a-service (PhaaS) tools like Tycoon 2FA use reverse proxies to intercept authenticated session tokens in real-time. This allows the platform to maintain an active session for the attacker to utilize later, even if they aren't actively browsing the account at this moment.
 - Even in the absence of immediate abuse, the successful access to the account is an incident. The attacker controls a full user session, requiring urgent session revocation and credential resets to prevent further exploitation.
- **Access granted, malicious activity:** A bad actor successfully accessed a user account and performed malicious actions through the account. In these cases, we observed bad actors doing several things, such as:
 - Registering a new MFA device, extending their access to the compromised account.
 - Searching mailboxes for internal communications.
 - Leveraging email accounts to interact with internal or external users as the compromised account.
 - Accessing cloud storage, SharePoint, Salesforce, or similar applications, likely in an attempt to access sensitive company documents.

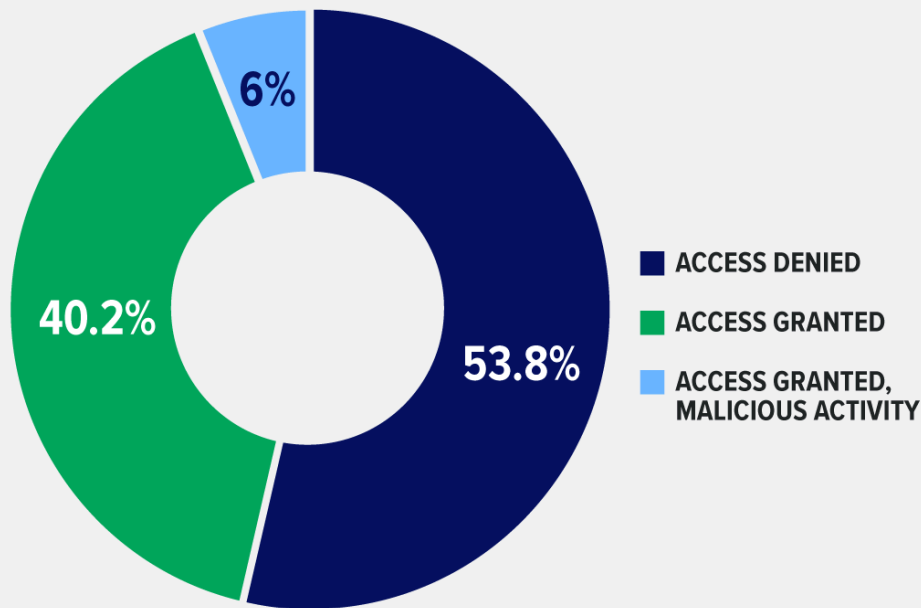
Here is what this data looks like for the second half of 2025:

Valid credential use in H2 2025

KEY TAKEAWAY

Only 6% of identity attacks Expel detected had evidence of further attack activity. Of that 6%, BEC was prominent.

Source: Expel



In 40.2% of the incidents, the attacker successfully authenticated to the account, but we didn't see them perform any additional actions. This can occur when the AiTM system intercepts the authentication flow; as the user logs in, the platform captures the resulting authenticated session token. Many AiTM systems will store these hijacked tokens until a human operator identifies the high-value victim and leverages the active session for further exploitation.

In 6% of incidents, we did see attackers use identity to gain a foothold within an organization and perform further malicious activities. Business email compromise (BEC) played a significant role here, where specific users were targeted to gain access to their accounts, often to steal sensitive information.

Phishing-as-a-service (PhaaS) trends

In the last few years, we've observed the commoditization of phishing infrastructure—primarily through phishing-as-a-service (PhaaS). PhaaS platforms are criminal service offerings that provide infrastructure and templates to carry out phishing campaigns. PhaaS is the leading contributor to increases in the volume of phishing emails.

Not only do these platforms facilitate more volume, they provide more capability. PhaaS platforms provide cybercriminals means to phish for MFA or steal session tokens, allowing attackers to intercept and authenticate despite the use of MFA.

Due to this increased sophistication and volume, it's critical for organizations to implement security controls to defend user accounts and identity.

PhaaS services are available for purchase on the dark web and are primarily intended for cybercriminals, but there are options for setting up infrastructure yourself. One of the best known PhaaS platforms is [Evilginx](#). Evilginx provides a man-in-the-middle framework which can steal credentials and session cookies.

In terms of internal audits, security improvements should focus on security controls to prevent account compromise. Cyber defense shouldn't be left up to end users. Defenses should focus on identifying and removing phishing emails before they're accessed by a user, phishing-resistant MFA, and ensuring secure configurations to defend against authentication downgrade attacks.

Our 2025 malicious phishing submissions also tell the same story—identity attacks dominated the threat landscape last year. **Attackers clearly prioritized credential theft.**

Most phishing emails we reviewed were credential harvesting attempts, where attackers trick users into visiting fake login pages, in the hopes they will enter their credentials.

Social engineering came as a distant second, where attackers attempted to manipulate recipients into carrying out various activities. Next up was malware, followed by extortion attempts—emails falsely claiming they have proof of illegal or embarrassing activity and demanding money to keep quiet.

FIELD NOTES

Identity: a solved problem?

03:40



JAMES SHANK
DIRECTOR, THREAT OPERATIONS

In many pursuits, the problems that arise in the operational day-to-day aren't new and aren't unsolved problems. They are normal, routine, or ordinary problems. Most problems aren't new discoveries—they're gaps.

For the last several years, identity-related compromises have been one of three top contenders for initial access vectors. Why hasn't it been solved?

The truth is, most of these identity compromise situations do have solutions aligned towards them. The technology itself isn't the gap—the gap is the lack of technology implementation.

Take password exposure, for example. How long have there been strong password storage solutions? Another example: MFA being bypassed through SIM swapping. Where were the passkeys or OAuth 2.0? And another: sign-ins using stolen cookies. What about behavior monitoring, geo-location checking, and device-bound session credentials ([DBSC](#))? (To be fair, DBSC hasn't fully rolled out.)

Technology currently exists to solve these problems and to fill these gaps. However, it's often not in place because security has to fight for resources against competing business interests.

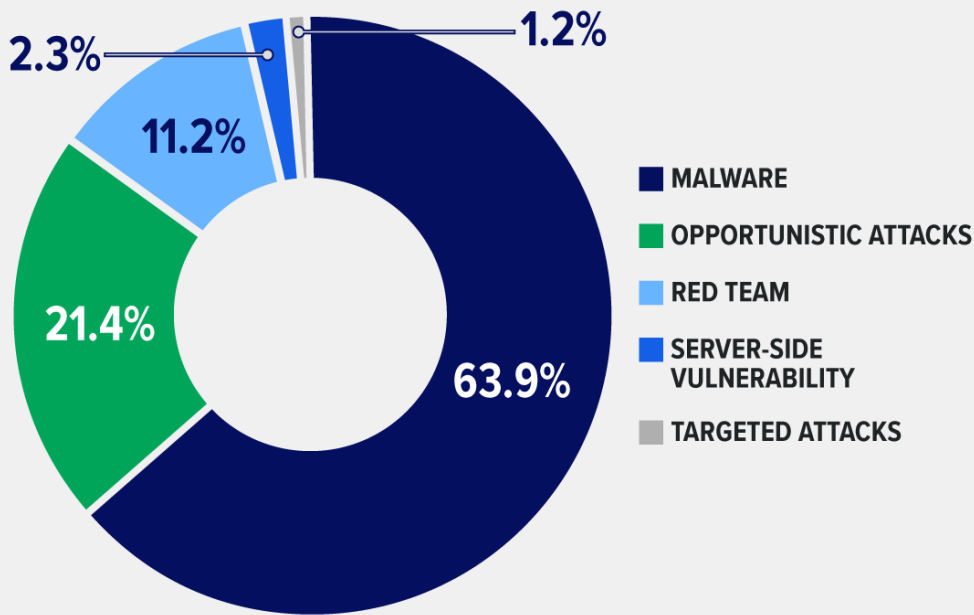
Risk mitigation considers impacts and likelihoods—both inside and outside cybersecurity. In reality, most companies are at higher risk of not knowing where their next dollar comes from than they are of falling to an identity compromise. We don't live in an ideal world, where security teams have every tool they need. Hence, our teams must focus on the basics to reduce impacts and must sometimes compromise (pun definitely intended) and do the best we can with the resources present.



ATTACK SURFACE TRENDS
Endpoint attacks: Malware is king

Endpoints are the second largest attack surface. While many sensitive files and data have moved to the cloud, user endpoints and servers remain prominent targets.

Threats to endpoints



KEY TAKEAWAY

Malware is the most significant threat vector for the endpoint surface seen in 2025.

Source: Expel

By far, the most common endpoint incidents involved malware (63.9%). In the incidents we fielded, these attacks were successful despite existing security controls, leading to a security incident and subsequent human intervention. Below, we'll discuss what malware families, tactics, and tools make up this category.

The second most frequent threat type were opportunistic attacks (21.4%). As the name suggests, these are attacks of opportunity, where an attacker doesn't necessarily target the organization. This is a broader category which involves attacks that don't fit a singular description. These incidents include activity such as attempted portscanning from an unmanaged computer, hands-on-actor commands originating from a compromised asset, and anomalous remote access tool usage. In most cases, the attacker has managed to gain control of the endpoint at the time of detection.

While opportunistic attacks cast a wide net, targeted attacks take the opposite approach—but are no less important. Targeted attacks are carried out by cybercrime groups or nation states and generally focus on a particular target or sector, rather than taking advantage of general weaknesses.

Targeted attacks made up 1.2% of the observed threats to endpoints.

Most noteworthy targeted attacks in our data have been sustained campaigns using Microsoft Teams. This isn't new—we've documented this activity for years and saw it surge [in April 2025](#). What stands out is the persistence: attackers will stay focused on individual targets for weeks. Other notable targeted activities include North Korean state actors, and [Scattered Spider](#)-adjacent actors running voice phishing operations.

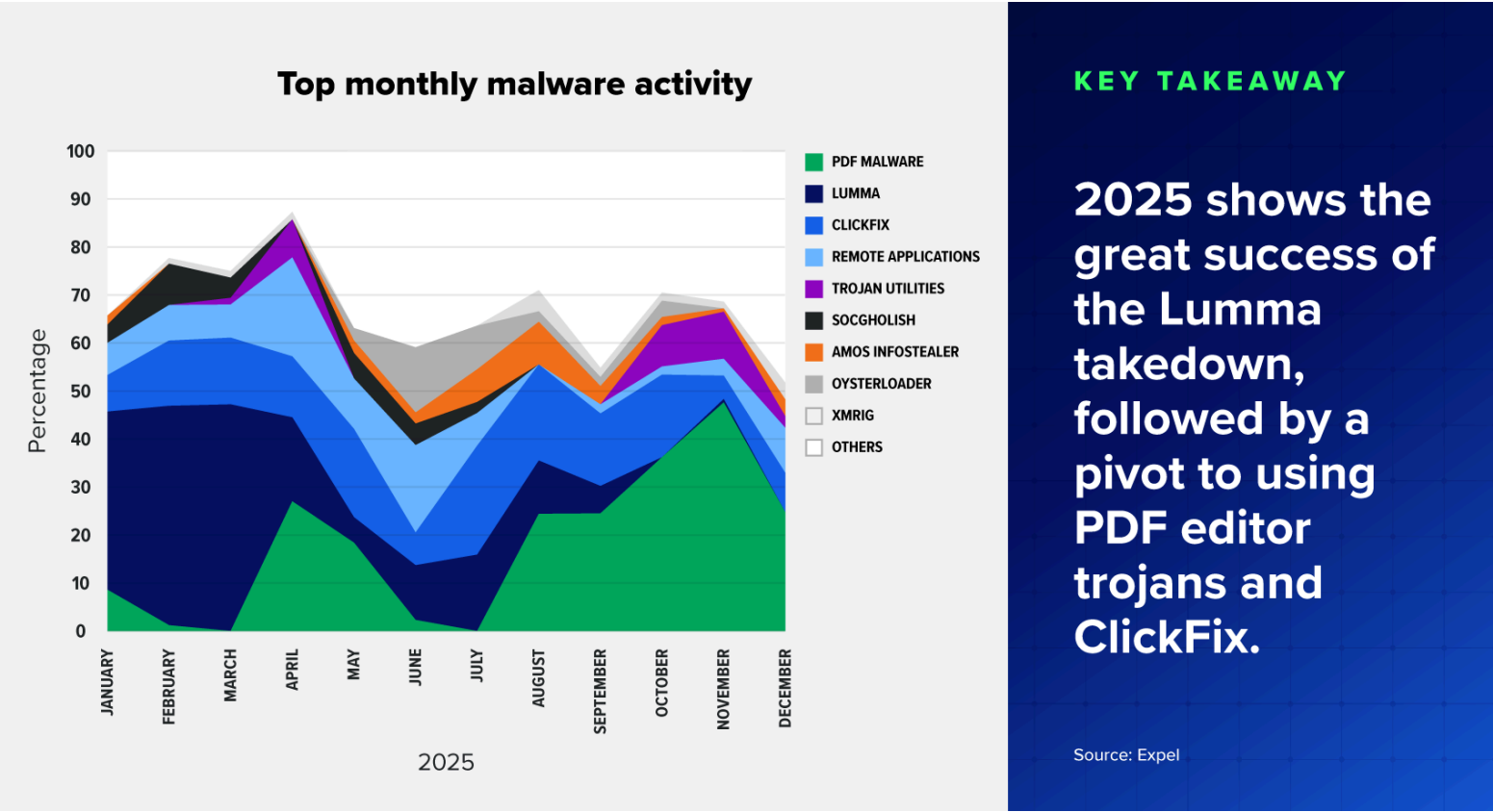
Server-side vulnerabilities represented another serious endpoint category, though they appeared less often (2.3%). In these incidents, attackers exploited vulnerabilities to compromise systems and gain network access. Some of the vulnerabilities we saw frequently in attacks this year included:

- React2Shell ([CVE-2025-55182](#))
- A PHP command injection vulnerability ([CVE-2024-4577](#))
- A New Technology LAN Manager (NTLM) vulnerability ([CVE-2023-23397](#))
- A WSUS remote code execution vulnerability ([CVE-2025-59287](#))
- Several different vulnerabilities used against Adobe ColdFusion servers

Finally, **we have categorized 11.2% of the incidents we saw as red team activity.** These are situations where we were alerted to abnormal activity on an endpoint, and through creating an incident and notifying the customer, we discovered they were performing security exercises to test the resilience of their environment.

Malware activity

The malware that we see and focus on in this report are malware families that evaded our customer’s first lines of defense and executed on hosts. The following analysis focuses on malware families we identified consistently throughout the year.



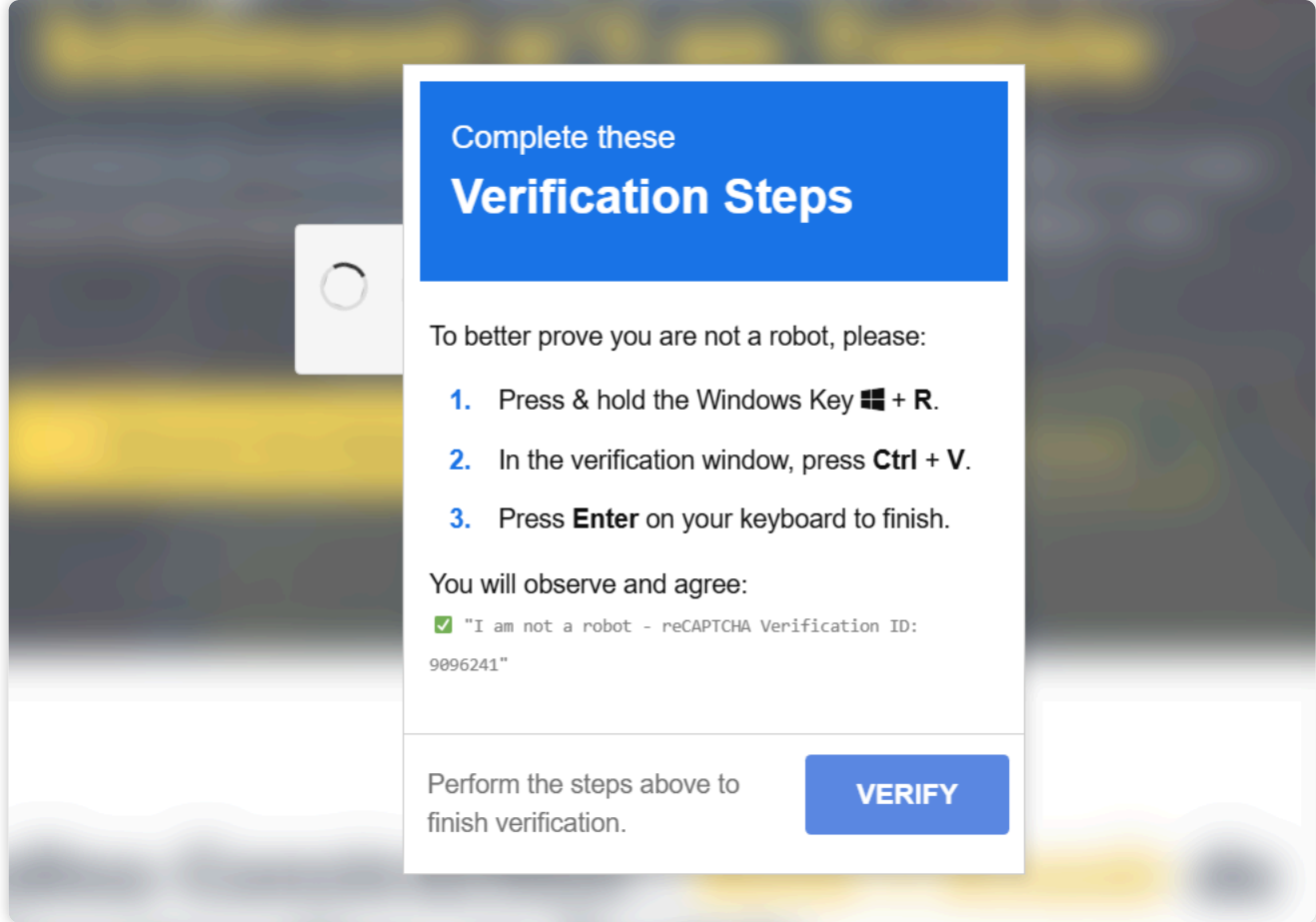
The decline of the champion

In 2024, we observed that [Lumma infostealer was the most prominent infostealing malware](#) by far, and the preferred infostealer of cybercriminals. This was also true for the first few months of the year, until the infrastructure behind the malware [was targeted by international law enforcement](#) in cooperation with private industry. This was a huge win for law enforcement and the cybersecurity community, resulting in a significant drop in malicious activity.

From our perspective, Lumma wasn’t eliminated as a threat; however, it’s clear that actors used it less frequently against our customer base. This seems to align with broader trends. [As reported by SpyCloud](#), cybercriminal trust in the Lumma infostealer service has continued to decline, causing criminals to navigate towards other infostealers such as Vidar and StealC.

The hot tactic

The hot tactic this year—like so many other years—isn’t new, but it’s still delivering wins for the actors. The ClickFix tactic bypasses several defenses by tricking the user into executing a script on their own system. This tactic leverages an infected webpage to display instructions for the user: most often suggesting for them to complete a CAPTCHA or follow other instructions on how to fix an issue. Following the commands results in malware being executed on the host.



The website puts a malicious command on the user's clipboard which ends with the "I am not a robot" statement. The statement pushes the malicious content out of view in the Windows Run window.

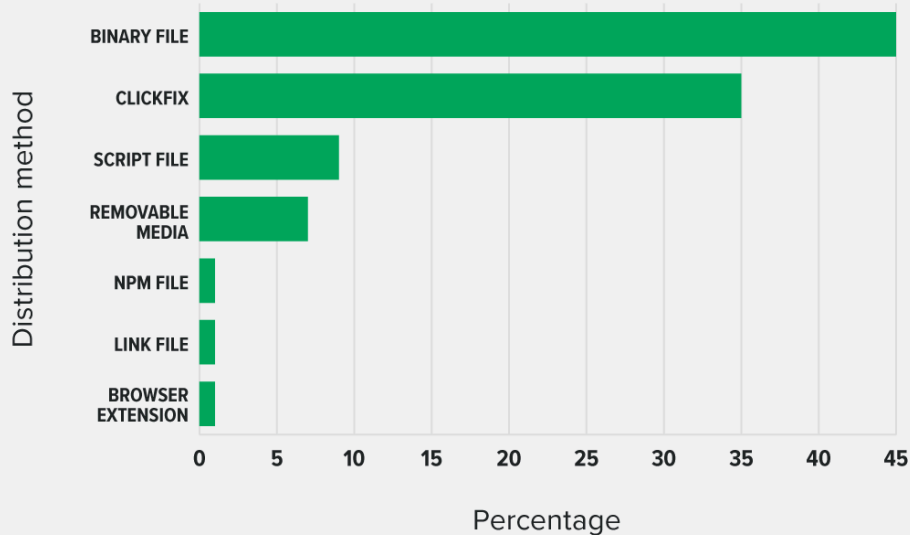
Over the last few years, we've seen infected webpages range from major financial service providers, to government websites, to pirated sports websites, and everything in between.

In 2025, we observed the following malware families distributed through this technique, among others:

- Lumma
- SocGholish
- NetSupport RAT
- MacSync

Incidents leveraging the ClickFix tactic accounted for 35.4% of all malware driven incidents. The following graph shows a breakdown of malware distribution methods. Each distribution method, such as ClickFix, requires its own unique security strategies to defend against.

Malware distribution method



KEY TAKEAWAY

ClickFix has become the second-highest distribution method for malware.

Source: Expel

The high volume of ClickFix-related attacks are facilitated by traffic delivery systems (TDS). A TDS allows the owner to define the criteria for delivering the malware. This allows bad actors to schedule delivery to side step analysis, drop malware based on the visitor's operating system, and customize other details. KongTuke and ClearFake are two major TDSs that are currently active and being tracked.

ClearFake, specifically, continually implements new innovations to minimize detection. We [recently observed and documented](#) their sole use of legitimate domains and their leveraging of Microsoft binaries to load the malware they deliver. Their use of the public blockchain also had the unintended consequence of giving us visibility into their total number of infections, shown below.

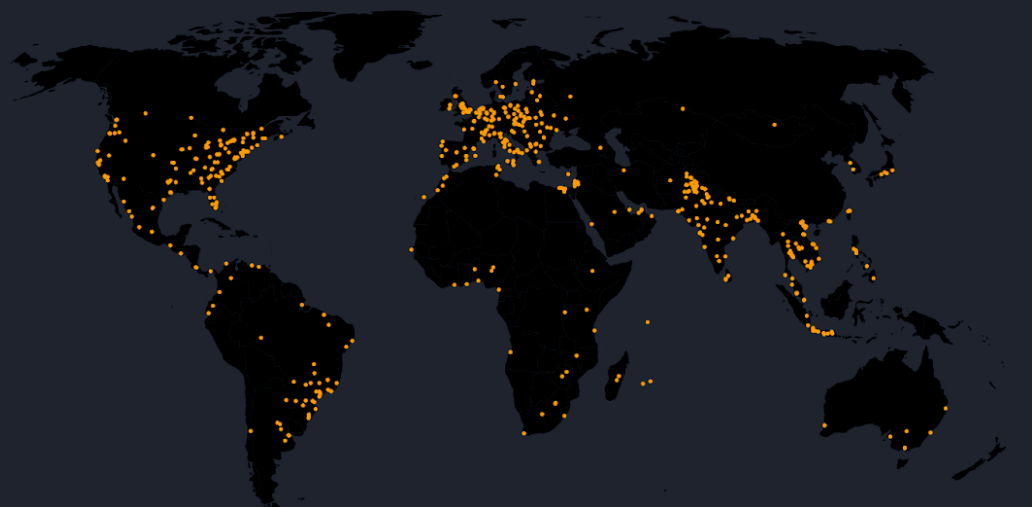
ClearFake infections

[Home](#) / [malware tracking](#) / [ClearFake](#)

218 past 24 hours

159,616 total

2026-01-16 12:21



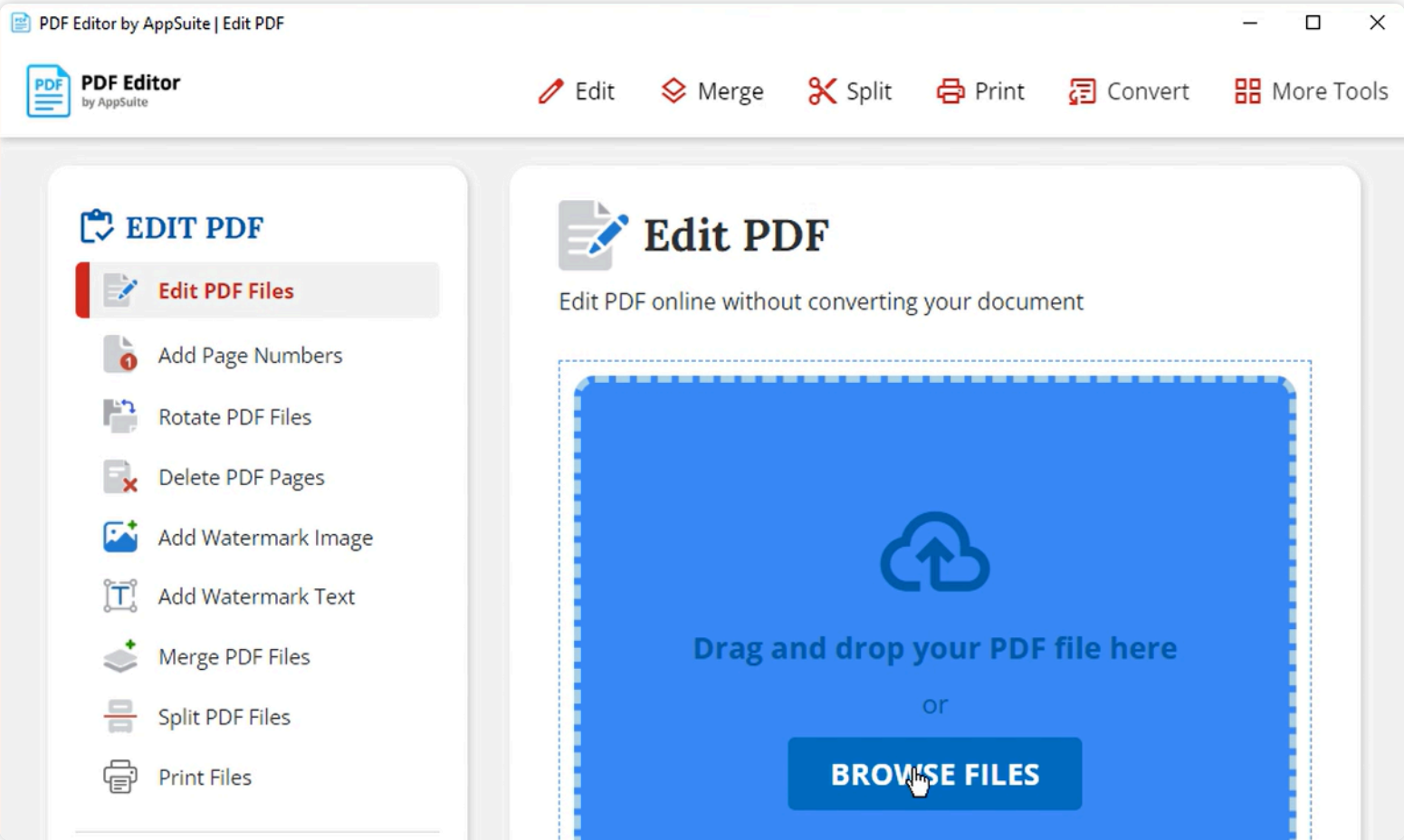
Backdoored productivity apps

[BaoLoader](#) featured prominently in our malware detections in the second half of last year. In August, we observed it originating from PDF editing software, using its backdoor to execute PowerShell for antivirus enumeration and [payload delivery](#). This PDF editing software had been observed for years, but this change in tactic exposed the threat actors’ backdoor. This resulted in Expel (and other security providers) building an array of detections to identify the backdoor and block it.

BaoLoader wasn’t the only malware posing as a PDF editor (or a similarly useful application). There were dozens of others offering the functionality that the user was seeking, but contained hidden malware alongside it. We classified these as trojans—functional apps used to install backdoors, hijack users’ browsers, and download arbitrary payloads in addition to their advertised functionality.

We saw three primary categories of these trojans: PDF editing tools, generic software apps, and AI helper apps. Each of these were primarily distributed through ads.

The largest group of these three were the PDF editing apps. While these tools were technically functional, that functionality was often a veneer. Some, such as BaoLoader, simply open a website in a custom application, while others just place a .LNK file on the desktop which points to a file conversion website. This façade allows the application to appear functional and hides the fact that a backdoor is installed or unauthorized changes are made to the user’s browser.



AppSuite PDF looks like a local application, but it’s actually just opening a webpage in a custom webviewer. Uploaded files leave the user’s device.

These apps present risks to organizations on multiple fronts. A user believes they are converting a file on their computer, but in most cases, these files are uploaded to a remote server and return a converted file. This causes users to unwittingly expose potentially sensitive documents. It’s unknown what becomes of these documents or why they are being collected.

The other main function of the malware is installing some sort of backdoor. These range from being able to execute arbitrary code, intercept banking information, and to access credentials stored in the browser.

The following are examples of these trojans:

Trojan PDF editors	Trojan utilities	Trojan AI apps
PDF Editor/AppSuite/PDF ProSuite	ConvertMate	JustAskJacky

PDFFast	Easy2Convert	
SupremePDF	RecipeLister	
PDFSkills	Calendaromatic	
PrimePDFConvert		
PDFSupernova		

FIELD NOTES

Stop downloading free PDF editors (please)



05:34



JAKE DOWNIE
SOC ANALYST

Please, for the love of SOC analysts like me, make sure your employees stop downloading free PDF editors.

Here's a story. Sue receives a form from her boss that needs to be filled out and sent to a client ASAP. The only issue is that her job doesn't provide licensing for a PDF editor. So she goes looking for a free PDF editor online.

She has so many options. PDFFast, PDFSkills, or even SupremePDF. Sue wants only the best, so she clicks on a link to download SupremePDF. The program installs, and she uses it. The software works enough for her to edit the form and ship it off without terribly inconveniencing her or her boss.

What Sue doesn't know is that SupremePDF is just a disguise used by malware to maintain a persistent hold on your system. Some days later, the security team is alerted to an attacker laterally moving on their network and stealing data. Tracking the source leads them right to Sue's machine. She tells them that she didn't click on any phishing links or give scammers access to her computer over the phone, so it couldn't have been her. Sue is informed that the PDF editor she downloaded was secretly malware that allowed the attacker access to her computer, and only used the ability to edit PDFs as camouflage to lull her into a false safety.

Now, this specific story is fictional; however, this scenario is not uncommon and happens more and more as attackers realize what an effective attack vector this really is.

These “PDF editors” are actually trojans, which use their safe-looking outer shell to establish a foothold on your endpoints. The malware maintains persistence, making sure that the software creates a service that runs on the endpoint, keeping the PDF editor running. We often see these editors then used as a backdoor to run malicious code on the host, commonly abusing encoded PowerShell to download a second payload.

These editors pose a significant risk. When they are initially downloaded, they usually don’t raise a “red flag” from an endpoint detection agent, as these files are usually signed and do not yet have a record of malicious behavior.

This software family is so appealing to users because PDFs are common in daily work and many companies don’t have enough legitimate PDF editor licenses for all employees. Users who only occasionally need to edit a PDF often lack a license and don’t want to ask for one. Making matters worse, software like this is also usually shared with coworkers through word-of-mouth and can commonly infect several machines at once, creating a ticking time bomb for your environment.

TL;DR, if your company’s employees don’t know that these applications are dangerous, you should let them know. Today.

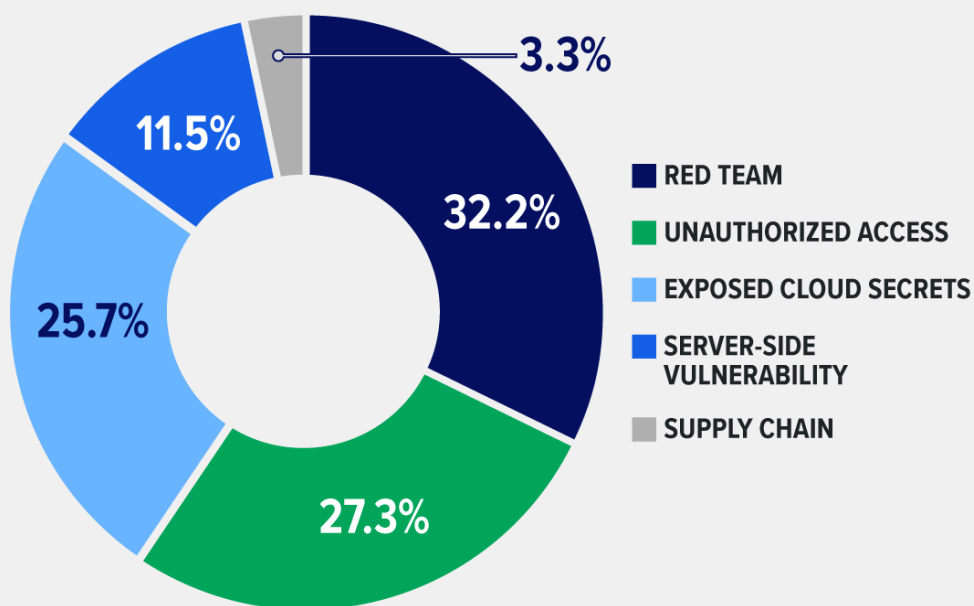


ATTACK SURFACE TRENDS

Cloud infrastructure attacks: Lower activity, higher risk

Attacks against cloud infrastructure remain a low volume but high impact threat. The following graph breaks down incidents involving this attack surface.

Threats to cloud infrastructure



KEY TAKEAWAY

Red teams generated the most detections in 2025 cloud incidents.

Source: Expel

When a threat is not a threat

The largest category of observed cloud infrastructure incidents was red team testing (32.2%). These incidents simulate real attacks and gaps in defenses, often identifying vulnerabilities or exposed secrets before cybercriminals do.

The tests in this category covered a wide range of technologies—including Amazon Web Services (AWS), Amazon Elastic Kubernetes Services (EKS), Google Cloud, Google Kubernetes Engine (GKE), and more. These tests also had a wide range of activities.

First, when targeting AWS environments, 24% of engagements used [server-side request forgery \(SSRF\)](#) to perform DNS rebinding to expose AWS instance metadata. This attack tricks vulnerable applications into exposing sensitive metadata, such as identity access management (IAM) role credentials. This is a serious weakness, well worth the attention it receives from red teams. An attacker who can access the IAM role credentials can pivot to the management plane, enumerate and exfiltrate data, escalate privileges, and take other critical actions.

Second, the red teams focused heavily on access management (62% of all engagements). Once they gained access (or were given access, such as in an “assumed breach” scenario), they used the credentials to understand how the account could be leveraged. This type of auditing is important in understanding the potential damage an exposed secret can cause, as we still commonly see accounts and access tokens being over-privileged. In the event that these credentials are exposed, it can result in a significant impact, and this is best discovered during an authorized audit—not an incident investigation.

Uninvited guests

The next largest category—unauthorized access (27.3%)—is made up of instances where attackers were able to access a device or deploy malware, due to cloud misconfigurations or other means.

In these cases, attackers often deploy cryptominers like XMRig. XMRig is a legitimate, open source, cryptocurrency miner often used to mine Monero. Attackers infect devices, with no discrimination between a high-power server and a small, forgotten development instance. If there’s a misconfiguration, they’ll find and capitalize on it.

XMRig offers cross-platform compatibility, enabling attackers to use the same tool in a variety of environments. [We’ve seen XMRig](#) across a variety of platforms, such as Windows endpoints, Linux hosts, Kubernetes pods, and AWS EC2 instances.

The presence of XMRig is a high-fidelity indicator of a deeper security failure. An attacker capable of deploying a miner may also be positioned to deploy ransomware or exfiltrate sensitive data; they have simply chosen cryptomining at their preference to profit off the compromise.

Finding the skeleton key

Exposed cloud secrets remained a critical security issue, accounting for 25.7% of cloud infrastructure compromises. In the modern cloud, a leaked API key is functionally equivalent to an administrator’s physical keycard; it grants the holder the ability to authenticate and interact with APIs at the access level granted to that key.

54% percent of the incidents were caused by attackers leveraging [the automated secret scanning tool, TruffleHog](#). TruffleHog, when used, performs a liveness check. This check attempts a benign API call “**GetCallerIdentity**” to verify if the key is active. For us, this behavior is an early warning of exposed cloud secrets and clear tell of TruffleHog. Cloud secrets are still frequently exposed by being hardcoded in applications or scripts.

Throughout the year, several supply chain attacks successfully exposed secrets, serving as a firm reminder of how significant the impact of supply chain compromise can be. In March, the [tj-actions Github Action](#) was compromised, and as a result running the workflow exposed credentials in the workflow’s logs, publicly exposing the secrets. In September and November, the Shai Hulud and Shai Hulud 2.0 worm (discussed more below) leveraged TruffleHog and custom scripts to identify and expose secrets stored on the impacted host.

Reacting to exploitation

Server-side exploitation featured prominently in cloud infrastructure incidents, where 11.5% of them involved vulnerabilities. Of these, one particular vulnerability stood out.

The end of 2025 and the start of 2026 saw a critical vulnerability which was a significant threat to cloud assets: React2Shell ([CVE-2025-55182](#)). This vulnerability was given a CVSS severity score of 10.

React2Shell is an unauthenticated RCE vulnerability. It stems from the unsafe deserialization of data sent to Server Function endpoints in React Server Components. An attacker can trigger the exploitation with a single, specially crafted HTTP POST request to a vulnerable application.

The threat to cloud infrastructure was particularly high because it affected core packages used by popular frameworks, like Next.js. That meant a vast number of cloud native applications were exposed by default. Thankfully, the vulnerability was responsibly disclosed and vendors implemented mitigations allowing defenders to start patching prior to active exploitation.

Supply chains cloud over

The end of 2025 saw a fundamental shift in the nature of supply chain attacks with the emergence of the Shai Hulud 2.0 worm. Unlike previous attacks that relied on manual typosquatting or one-off compromises, [Shai Hulud 2.0](#) is a self-replicating entity that weaponizes the “trust layer” of the software supply chain.

The attack typically begins with a phishing campaign targeting NPM package maintainers. Once a maintainer’s account is hijacked, the worm automatically modifies every package that developer maintains.

- **Malicious pre-install scripts:** Shai Hulud 2.0 uses pre-install or post-install hooks to execute code the moment a developer or CI/CD runner types `npm install`.
- **The “worm” effect:** If the worm detects a valid NPM token on the new victim’s machine, it immediately republishes malicious versions of that developer’s packages, creating an exponential “blast radius” that has impacted over 700 packages to date.

For cloud native organizations, the threat is particularly acute because the worm is designed to harvest IAM secrets.

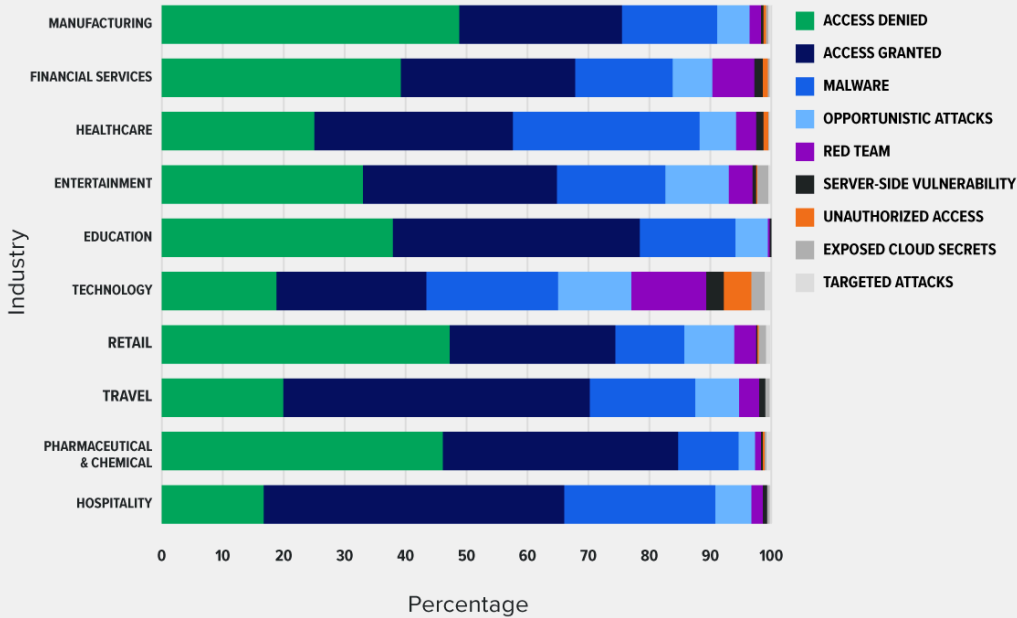
- **Cloud credential harvesting:** The worm scans environment variables and local config files for AWS, Google Cloud, and Azure service principal keys. The worm even deploys tools like TruffleHog within the build environment to ensure no secret is missed.
- **CI/CD persistence:** We observed incidents where the worm successfully injected malicious GitHub Actions workflows into existing repositories. This allows the attacker to maintain a permanent backdoor in the build pipeline, exfiltrating new secrets every time code is pushed, long after the original malicious package has been removed.
- **Data exfiltration via GitHub:** In a clever move to evade network security, Shai Hulud 2.0 exfiltrated stolen cloud keys to public GitHub repositories labeled “**Shai-Hulud: The Second Coming**,” masking malicious data transfer as legitimate developer traffic. This use of specific strings creates a great detection opportunity (which we then used to find impacted customers).

ATTACK SURFACE TRENDS

Industry insights

Not all industries are targeted equally, and often the success of different attack tactics and techniques is different against various industries. Here are the industries we see targeted most, and the types of threats they face as a whole.

Incident types by industry



KEY TAKEAWAY

Identity (access denied and granted incidents) leads the pack as the most prominent attack surface across all industries.

Source: Expel

Organizations in every industry have their user accounts targeted, often making up 60–70% of the incidents seen within the industry.

Manufacturing, financial services, and healthcare are the top three industries that saw the most incidents, respectively. However, healthcare saw far more malware incidents than manufacturing, and financial services saw more incidents involving valid credentials than healthcare.



Defending attack surfaces

Our 2025 data yet again proved something we've always known to be true: In security, the fundamentals should always be the top priority. Avoid chasing the headlines. Real-world attackers overwhelmingly favor the path of least resistance: unpatched systems, inadequate authentication verification, and basic social engineering.

By securing the basics first (strong authentication, timely patching, least-privilege access, network segmentation), you'll prevent far more incidents than chasing the latest threats ever could. Simply put, while the clever attacks get the most attention, it's the simple ones that result in more incidents.

Looking for concrete steps you can take to shore up your defenses? Here is a (non-comprehensive) list of things you can do to protect your environment in 2026, based on the threats we observed in 2025.

Identity

- Ensure there are conditional access policies for authentication in place at your organization.
- From our perspective, organizations with policies that require authentications to originate from trusted devices are the most likely to prevent unauthorized access. While this configuration may not be possible for all users, it should be considered for the most critical accounts and accounts with high amounts of access.
- Use security policies and tools to minimize the threat of phishing.
- Secure email gateways and similar products can filter out a substantial amount of phishing emails before they're received by users.

- Audit and evaluate your current authentication requirements. Some forms of MFA are no longer effective against phishing. When possible, use MFA following the [FIDO2 standard](#). These methods use biometrics, physical tokens, and certificates to ensure the user is who they say they are, and the website they're attempting to access is legitimate.
- Ensure that red teams also audit your identity security controls.
- Red teams can help identify weaknesses in existing controls and identify the "blast radius" or potential impact of a compromised account.
- **For Expel customers:** Consider enabling [account disablement as an auto remediation action](#). This allows Expel to quickly contain identity-based incidents, drastically closing the gap between signal and action and ultimately minimizing the attack impact.

Endpoint

- Disable the use of the Windows Run hot key (Windows + R).
 - [This can be done via GroupPolicy](#). The majority of ClickFix attacks take advantage of this hotkey and disabling it can prevent many of these incidents.
- Whenever possible, ensure employees have official means for downloading approved applications.
 - Many incidents we observe are the result of malicious advertising for common software such as Microsoft Teams, Slack, and RVTools. An official means for acquiring these tools ensures users get the tool they need instead of malware.
 - Application whitelisting and Application Control for Windows can also block unwanted applications. We recommend proactively blocking remote management tools which aren't expected in your environment. These tools are frequently abused to obtain remote access to networks.
 - Application whitelisting can also prevent users from installing and running trojanized productivity tools.
- **For Expel customers:** We recommend enabling [the contain host auto remediation](#). This allows the Expel SOC to contain hosts automatically when an endpoint incident is identified, and reduces the impact of incidents by closing the gap between detection and remediation.

Cloud infrastructure

- If you use package managers such as NPM (or others), it's important to monitor and control what happens in this environment.
 - Configure your package manager to disable lifecycle scripts. This can prevent unauthorized code from executing during package installation.
 - Consider implementing version pinning, which will prevent packages from updating until you've had a chance to vet any changes in newer versions.
 - For deployment of your own NPM packages, require MFA so attackers cannot publish compromised updates to your package registry if they manage to obtain credentials.
- Implement proactive secret key security and monitoring.
 - Use tools like TruffleHog or Github Secret Scanning in CI/CD pipelines to catch keys before they are committed and exposed.
 - Transition from long-term IAM access keys to IAM roles and OIDC for automated workflows to enforce short-lived credentials.
 - Use a secrets manager to rotate keys every 30-90 days automatically.
 - Use least privilege access policies to ensure all API keys have restricted permissions. Never use **AdministratorAccess** for integration keys.
 - Consider creating a pre-defined automated script to immediately revoke and rotate any key identified as exposed.
- Harden AWS instance metadata service (IMDS) settings.
 - Use the AWS cli to identify instances still using IMDSv1. [Look for the MetadataNoToken metric in CloudWatch; if it's above zero, IMDSv1 is being used.](#)
 - Implement an IAM service control policy (SCP) or regional default setting to require IMDSv2 for new instances.
- Monitor for cryptomining installations.
 - Enable AWS GuardDuty for basic cryptomining detection, and turn on Runtime Monitoring for comprehensive protection against unauthorized miners.
 - For Kubernetes, review pod security policies, ensuring that baseline profiles are enabled. This should guard against many cryptomining scenarios, but in some situations it may be worth considering restrictive profiles to protect highly sensitive data.
 - Monitor for outbound connections used by mining pools, such as DNS queries to mining pool domains and on commonly used ports.
 - Some threats can be configured to use encrypted traffic, hiding these connections, so look for unusual encrypted connections as well.

- **For Expel customers:** We recommend enabling the [disable access key auto remediation](#). This allows the Expel SOC to issue a remediation to disable a long-term AWS IAM access key when it is determined to be compromised, effectively shutting down the key to prevent further abuse of it.



Signal vs. noise: making the most of alerts

Greater alert precision: Expel detections

[Alert fatigue is real](#). It's a key challenge in cybersecurity, where understaffed security teams can become desensitized to the constant stream of alerts generated by security tools. When these tools produce more notifications than analysts can field, it's not uncommon for them to be ignored or dismissed without investigating, increasing the risk of a real threat slipping through.

Oftentimes vendor-provided detections are built for the average organization, which means they're optimized for no one. They prioritize breadth over depth, can leave critical coverage gaps, and flood teams with low-fidelity alerts while missing threats that matter the most.

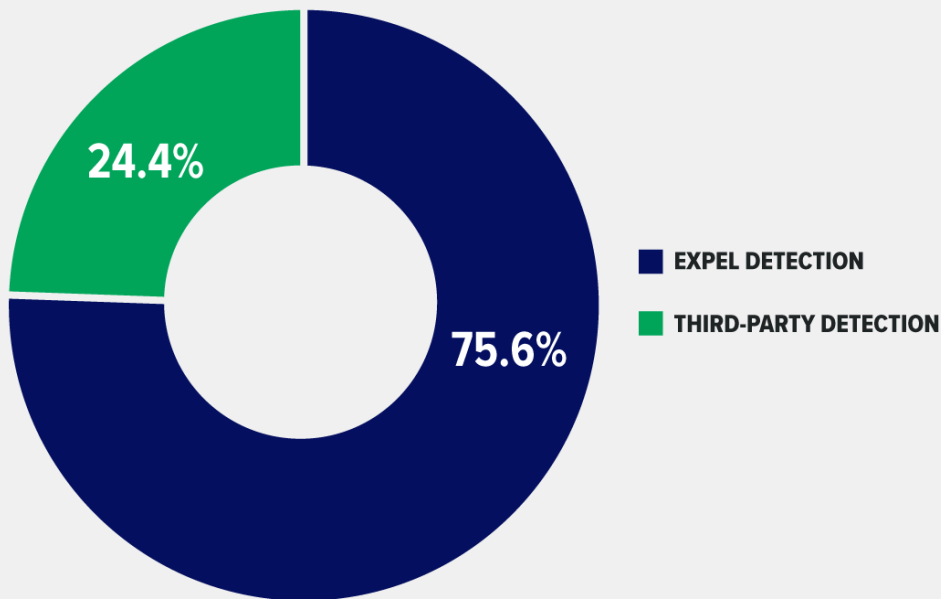
This is where Expel's detection framework can make a clear difference. We already ingest the alerts from hundreds of tools, across a wide range of vendors. But our detections are specifically engineered to cut through noise and focus on high-fidelity alerts that matter most to your security posture.

Our detection logic works differently, giving you what matters most: signal quality, coverage priorities, and responsiveness when dealing with security alerts. This means we catch attackers quickly instead of long after they've established a foothold, because we're working from actionable signals, not irrelevant noise. We do this several ways, often by evaluating potential threats through contextual risk factors. Sometimes it's as simple as elevating low-severity alerts that we know—through experience—tend to trigger during an event. Other times, we combine a series of low-fidelity alerts that—again, in our experience—tend to indicate that something nefarious is going on.

Given where we sit we can even cross-reference events across vendors to identify when something out of the ordinary is taking place. Or, if we don't see anything that adequately alerts us to activity we've previously witnessed, we write our own detections from the ground up.

But don't just take our word for it. Let us show you how we've performed in the last year.

Detection source



KEY TAKEAWAY

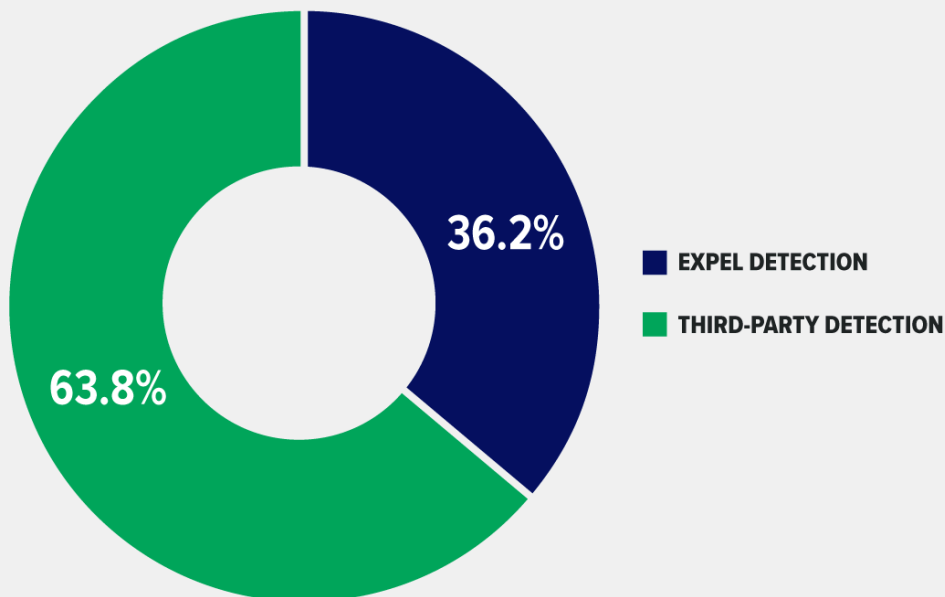
Expel's custom and enriched detections deliver more true positives than traditional vendor tool detections.

Source: Expel

The value Expel adds to detection precision is notable. **Across all detections that we monitor to protect our customers, 75.6% were either written from scratch by Expel or enhanced by Expel's detection engine.** Only 24.4% of the time did we rely on the vendor alert by itself.

But how do these detections stack up when we look across the incidents we've fielded in 2025? First off, let's look at all the alerts we saw, regardless of severity.

Expel detections in incidents



KEY TAKEAWAY

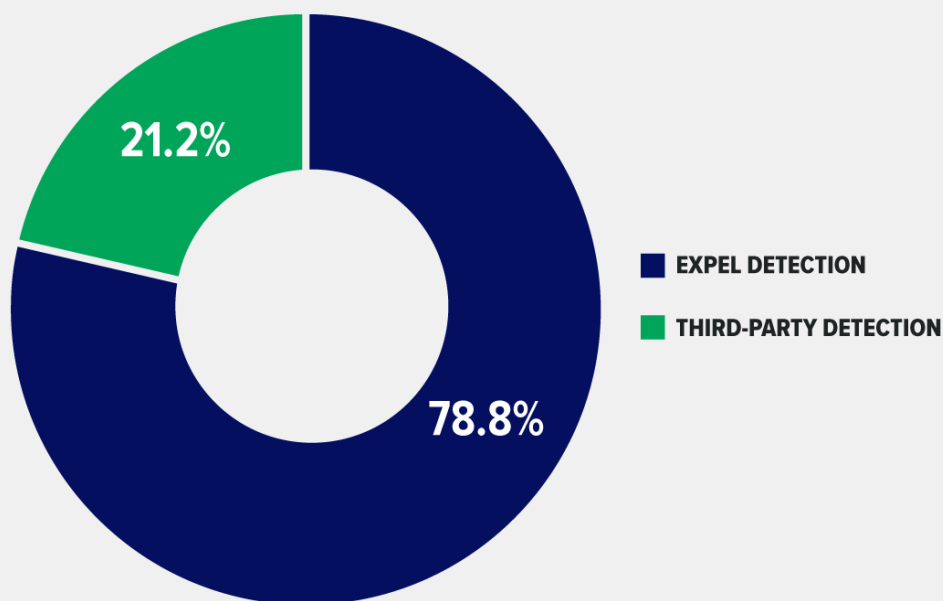
Third-party detections dominate overall, but most of these incidents were low-severity.

Source: Expel

Here, vendor detections dominate, comprising 63.8% of the alerts that we saw during the year. Most of these vendor detections focus on identity attacks, where bad actors have attempted to use valid credentials, but have failed to gain access. These types of incidents are important to flag—they involve legitimate credentials after all—but since they were stopped in their tracks, we classify them as low severity.

Now to really dial this in, let's narrow down our scope to look at high and critical severity detections only. This chart tells a very different story.

Expel detections in critical/high incidents



KEY TAKEAWAY

When incidents demand attention, Expel's custom and enriched detections give Expel analysts and customers an edge.

Source: Expel

In these important cases, Expel detections picked up the activity in 78.8% of the incidents we saw. This showcases that, while all these detections warrant response, Expel detections tune things in a manner that lets you quickly prioritize what needs your attention now, highlighting high and critical incidents in a way that allows you to respond accordingly.

So there you have it—the impact is clear. Organizations that leverage Expel's detections alongside their existing security stack see measurable improvements in overall fidelity. Rather than adding another alert source, our system acts as an intelligent layer that enhances and refines signals from other vendors.

Our MDR perspective grants an advantage: every customer who utilizes our detections contributes to making them better. Every environment shares edge cases and all of it feeds back into detection improvements. When one customer helps us tune a detection, every customer reaps the rewards. And each time this happens, it becomes part of a shared knowledge base that elevates the security baseline for everyone, creating a rising tide that lifts all boats.

And that doesn't even get into the fact that our SOC still triages the alerts, can handle the response, and provide recommendations on how to stop the detected activity and prevent it from occurring again. But that's a story for another day.

FIELD NOTES

Developing new detections to combat remote monitoring and management tools (RMMs)

**CHRIS WAGNER****DETECTION & RESPONSE ENGINEER**

In 2025, we witnessed an increase in the malicious use of RMMs. On the surface, this is a difficult activity to build detections around, because RMMs also have many legitimate business use cases—for example, when your IT team has to remotely access your laptop to get rid of that weird notification that won't go away.

So we set out to create something to help make this complex detection a little more manageable. We had to do so without triggering a ton of benign alerts for analysts to deal with for appropriate RMM usage, but we also didn't want to burden the customer with maintaining a list of RMMs that were acceptable to them. Plus, RMM name consistency isn't dependable, so relying on customers and then having to translate that into specific terms for detections seemed like more of a hassle than help.

Instead, we created five new detections in conjunction with Ruxie's automation capabilities to help us address RMM complexity:

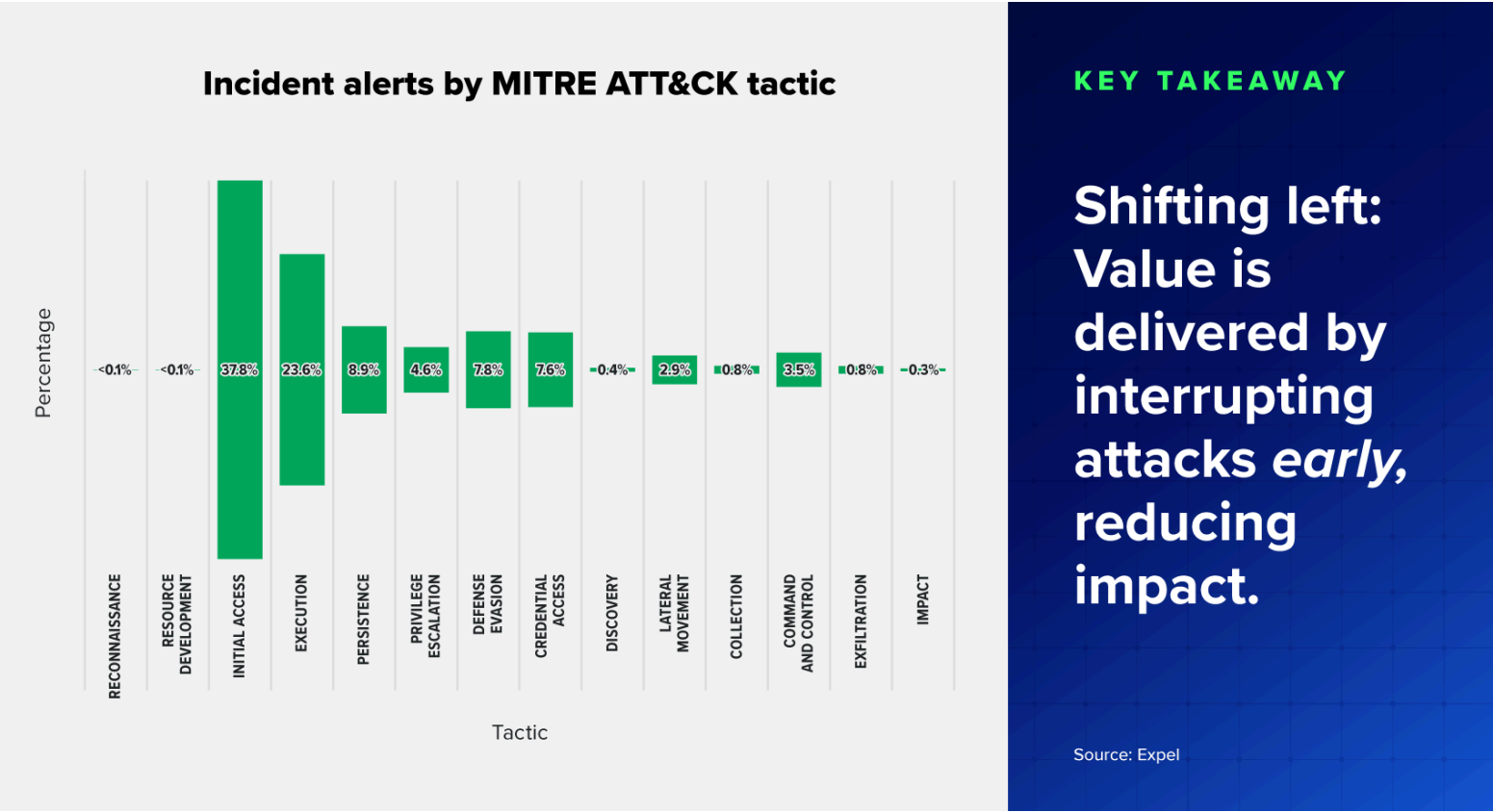
1. The first detection is simply an ongoing (not yet exhaustive, unfortunately) list of known RMMs. Specifically, this detection alerts when an RMM is the source process of an alert and the RMM tool is not prevalent in the customer's environment.
2. The second detection looks for multiple RMM tools on a single host. Attackers know some targets are softer than others, so they will try multiple RMMs in succession until they succeed.
3. The third detection correlates multiple RMM-associated network connections coming from a single host.
4. The fourth detection looks for some RMMs we've identified that only do malicious work, so their presence should always trigger an alert.
5. The fifth detection looks for RMM tools using non-standard ports. A normal user would not change this part of an RMMs configuration, so it's suspicious to see one using a non-standard port.

All five of these alerts have their own thresholds we've set based on our industry experience, so that SOC analysts are getting actionable, high-fidelity alerts. These detections also work well to layer context on additional alerts, and that's incredibly valuable, too.

Faster response: MITRE ATT&CK & Expel detections

Detection quality isn't just about accurately detecting attacks—response time can be just as critical. The earlier you catch an attack in the kill chain, the more opportunities you have to contain it before the real damage takes place.

When we mapped the detections in incidents we fielded in 2025 against the MITRE ATT&CK framework, a clear pattern emerged. Our detection of incidents is heavily weighted toward the left side of the kill chain.



This means we’re catching bad actors during the initial access and early execution phases, rather than when they’re exfiltrating sensitive data or deploying ransomware.

In cybersecurity, success isn’t measured by how many alerts you see. Rather it’s measured by how quickly you spot and stop real threats.

By combining high-fidelity detections and early stage threat detection, Expel addresses the noise and the alert fatigue that comes with it. Our data backs this up, and most importantly, so do the security teams who no longer dread opening their dashboards each morning.

Predictions for 2026

“I don’t think we’ll see AI eliminating existing cyber jobs. We may see fewer open positions as companies navigate AI usage for efficiency, but you can bet those open positions will be filled by people that have cyber *and* AI skillsets.

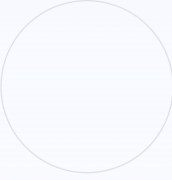
“The adversary is still a human being. That human being will figure out how defenders are using AI, and exploit those behaviors to their advantage. That will require a human defender to identify and counter.”

Dave Merkel
CEO & Co-founder

“The key themes CISOs are concerned about remain the

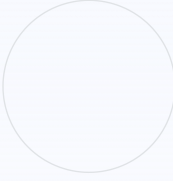
- Managing identity risks, especially with third and fourth party identities gluing together their SaaS estates
- Budgetary pressures
- Supply chain risks in both their own software supply chain and SaaS providers
- Getting their arms around AI risks and governance

“Many CISOs believe that AI will provide automation opportunities in their environments to free up people to work on some of the higher value tasks on their face. The jury is out on whether that will come to fruition.



Greg Notch
CSO

what to do, who to call, and react quickly. No organization may be the Trojan horse nation-state actors need to disruption.”



Pierre Noel
EMEA Field CISO

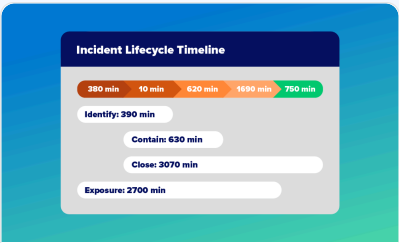


More resources



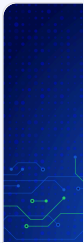
The CISO-CFO disconnect: why security and finance struggle on cyber investment

300 security and finance leaders reveal where alignment breaks down—and what actually fixes it



SOC Efficiency Metrics & KPIs Template

Learn what’s working and where to improve your security operations with this SOC metrics and KPIs dashboard tool



Expel

Expel
intelligence
protection
workload
action

Plans & Packages	Phishing	Newsroom	Identity
	detection & prevention	Resources	Network
	Threat Hunting	Blog	SaaS
	24x7 Security	Webinars	SIEM
	Operations	Cyberspeak glossary	Amazon Web Services (AWS)
	AI & Automation	Expel Intel	Google Cloud
	Engine		Kubernetes
	Meet the SOC experts		Microsoft
	Workbench™		Oracle Cloud Infrastructure (OCI)
	Operations		
	Platform		

ALSO OF INTEREST

- [AI and Automation Engine for Defense](#)
- [Phishing Detection and Prevention Solutions](#)
- [Security without compromise](#)